

VindobonaPay GmbH — Risk Register

Deliverable 01 | Asset-based risk assessment (ISO/IEC 27005 / NIST SP 800-30, simplified) | 5x5 matrix | Version 1.1 | Fictional company for educational purposes

Risk ID	Asset	Risk description (threat / vulnerability)	Consequence	Inh. Likelihood	Inh. Impact	Inherent score	Inherent level	Existing controls	Res. Likelihood	Res. Impact	Residual score	Residual level	Treatment decision	Treatment action / retention rationale	Related Annex A controls	Risk Owner	Action Owner	Target date	Status
R-01	Payment platform	DDoS attack against the public payment service; limited anti-DDoS measures beyond cloud defaults.	Service outage, SLA breach, revenue loss and reputational damage.	4	4	16	Critical	Azure availability zones redundancy; capacity monitoring (A.8.6, A.8.14).	2	4	8	Medium	Modify/Mitigate	Enable Azure DDoS Protection on public endpoints and document response runbook.	A.8.6, A.8.14, A.5.30	CTO	IT Manager	Q4 2026	In progress
R-02	Customer payment data	Compromise of a privileged account (stolen credentials); administrative accounts are protected by MFA, but not yet by phishing-resistant methods, and just-in-time elevation is not enforced.	Large-scale breach of payment and personal data; GDPR and regulatory impact.	4	5	20	Critical	MFA and Conditional Access enforced for all users (A.8.5); separate admin accounts; quarterly privileged access review partially in place (A.8.2).	2	5	10	High	Modify/Mitigate	Roll out phishing-resistant MFA (FIDO2) for all privileged accounts and introduce Privileged Identity Management (just-in-time elevation).	A.8.2, A.8.5, A.5.18	CISO	IT Manager	Q3 2026	In progress
R-03	Employees	Phishing campaign leading to credential theft; staff of a licensed payment institution are a frequent target.	Unauthorized access to mailboxes and internal systems; possible fraud attempts.	5	4	20	Critical	Yearly awareness training and phishing simulations (A.6.3); mail filtering and EDR (A.8.7).	3	3	9	Medium	Modify/Mitigate	Introduce phishing-resistant MFA (FIDO2 keys) for administrators and finance staff.	A.6.3, A.8.7, A.8.5	CISO	IT Manager	Q1 2027	Open
R-04	Endpoints	Ransomware infection on a company laptop spreading to shared resources.	Data encryption, operational disruption, potential extortion.	4	5	20	Critical	EDR on all endpoints (A.8.7); automated backups with restore tests (A.8.13); MDM hardening (A.8.1).	2	4	8	Medium	Modify/Mitigate	Extend application allow-listing to all servers and complete endpoint hardening baseline.	A.8.7, A.8.13, A.8.1, A.8.19	CISO	IT Manager	Q4 2026	In progress
R-05	Cloud infrastructure	Misconfiguration of an Azure resource (e.g. storage account exposed to the internet); cloud hardening baselines only partially defined.	Exposure of internal or customer data, regulatory impact.	4	4	16	Critical	Azure subscriptions partially aligned to CIS benchmarks; Defender for Cloud secure score monitored (A.8.9); Cloud Services Policy (A.5.23).	3	4	12	High	Modify/Mitigate	Complete cloud configuration baselines and enable continuous configuration drift detection (Defender for Cloud).	A.8.9, A.5.23	CTO	IT Manager	Q4 2026	In progress
R-06	Critical ICT suppliers	Failure or security incident at a critical ICT service provider; structured supplier reviews not yet in place.	Service disruption and possible data exposure; DORA third-party risk obligations.	3	4	12	High	Supplier list with risk rating (partial, A.5.19); security clauses in main contracts (A.5.20).	3	3	9	Medium	Modify/Mitigate	Define ICT supply chain risk procedure and yearly supplier review cycle (DORA-aligned).	A.5.19, A.5.21, A.5.22	Compliance Officer	Compliance Officer	Q1 2027	Open
R-07	Payroll data	Data breach at the outsourced payroll provider.	Exposure of employee personal and salary data; GDPR notification duties.	3	4	12	High	Contractual security and breach notification clauses (A.5.20); NDA; provider ISO 27001 certified.	2	3	6	Medium	Share/Transfer	Risk shared contractually; liability and part of the notification duties sit with the provider. Accountability for the personal data and the residual risk remain with VindobonaPay as controller. Verify provider certification yearly. Approved by: CFO. Review: 31 December 2026.	A.5.19, A.5.20	CFO	Compliance Officer	Q4 2026	Ongoing
R-08	Payment data / internal systems	Insider misuse of legitimate access to payment data; segregation of duties matrix still in draft.	Fraud or data leakage by an internal user; hard to detect without monitoring.	3	5	15	High	RBAC on payment systems (A.8.3); logging partially centralized (A.8.15); SoD matrix in draft (A.5.3).	2	4	8	Medium	Modify/Mitigate	Finalize segregation of duties matrix, complete quarterly access reviews and extend log coverage.	A.5.3, A.5.18, A.8.3, A.8.15	CISO	IT Manager	Q4 2026	In progress
R-09	Company laptops	Loss or theft of a laptop during remote/hybrid work.	Potential exposure of locally stored data.	4	3	12	High	Full-disk encryption on all laptops; MDM remote wipe (A.7.9, A.8.1).	2	2	4	Low	Retain/Accept	Residual risk retained: encryption makes data unreadable and remote wipe is available. Residual level Low, within acceptance criteria. Approved by: CFO. Review: 30 June 2027.	A.7.9, A.8.1	CFO	IT Manager	—	Accepted
R-10	Payment application	Exploitable vulnerability in the in-house payment application.	Fraudulent transactions, data exposure, service disruption.	4	4	16	Critical	SAST in the CI pipeline; yearly external penetration test; code review before merge (A.8.25-A.8.29).	3	3	9	Medium	Modify/Mitigate	Add DAST to the CI pipeline and formalize the secure SDLC procedure.	A.8.25, A.8.26, A.8.28, A.8.29	CTO	Head of Engineering	Q1 2027	Open
R-11	Servers and endpoints	Exploitation of unpatched systems; patch SLAs not yet defined by severity.	System compromise via known vulnerabilities.	4	4	16	Critical	Monthly vulnerability scans (A.8.8); EDR detection (A.8.7).	3	3	9	Medium	Modify/Mitigate	Define patch SLAs by severity and track remediation in monthly reports.	A.8.8	CISO	IT Manager	Q3 2026	In progress
R-12	Finance processes	Business email compromise / payment fraud targeting finance staff.	Fraudulent outgoing payments; direct financial loss.	3	4	12	High	Awareness training (A.6.3); segregation of duties partially in place (A.5.3).	2	4	8	Medium	Modify/Mitigate	Introduce dual approval for outgoing payments above threshold and a callback verification procedure.	A.5.3, A.6.3	CFO	CFO	Q3 2026	In progress
R-13	IT operations knowledge	Key person dependency in the small IT team; procedures only partially documented.	Operational disruption if key staff are unavailable.	3	3	9	Medium	IT runbook in progress (A.5.37); shared admin knowledge for core systems.	3	2	6	Medium	Modify/Mitigate	Complete documentation of key IT and security procedures.	A.5.37	CTO	IT Manager	Q4 2026	In progress
R-14	Regulatory compliance	Failure to meet DORA incident reporting deadlines; dedicated regulatory reporting procedure not yet defined.	Regulatory sanctions and reputational damage with the FMA.	3	4	12	High	Incident Response Plan with triage criteria (A.5.24); legal & regulatory register (A.5.31).	2	3	6	Medium	Modify/Mitigate	Define a regulatory incident reporting procedure with DORA timelines (covered in Deliverable 05).	A.5.24, A.5.31	Compliance Officer	Compliance Officer	Q1 2027	Open
R-15	Server room	Physical intrusion into the office server room.	Theft or tampering of local equipment.	2	3	6	Medium	Badge access and visitor register (A.7.2); locked server room (A.7.3); CCTV and alarm (A.7.4).	1	3	3	Low	Retain/Accept	Residual risk retained: physical controls in place and limited on-premises footprint. Residual level Low, within acceptance criteria. Approved by: Management. Review: 31 December 2026.	A.7.1, A.7.2, A.7.3, A.7.4	COO	Office Manager	—	Accepted
R-16	Microsoft 365 services	Prolonged Microsoft 365 outage affecting daily operations.	Temporary loss of email and collaboration tools.	2	4	8	Medium	Business Continuity Plan draft (A.5.29); Microsoft SLA; payment platform not dependent on M365.	2	3	6	Medium	Retain/Accept	Residual risk retained: multi-cloud setup not cost-justified; core payment service unaffected. Residual level Medium, retained with documented rationale under the acceptance criteria. Approved by: CFO. Review: 31 December 2026.	A.5.29, A.5.30	COO	IT Manager	—	Accepted

Score = Likelihood (1-5) x Impact (1-5). Inherent = before existing controls; Residual = considering existing controls.

Risk levels: Low (1-4) | Medium (5-9) | High (10-15) | Critical (16-25). Likelihood and impact band definitions, impact dimensions and risk acceptance criteria are defined in the 'Scales & Criteria' sheet.

Risk IDs are referenced in the 'Related Risk ID' column of Deliverable 02 — Statement of Applicability.

Risk Scales & Acceptance Criteria

ISO/IEC 27001 Clause 6.1.2 requires the risk assessment process to establish risk criteria, including criteria for accepting risk.

Likelihood scale

Rating	Band	Definition
1	Rare	Not expected within the next 5 years; no known occurrence in comparable organizations.
2	Unlikely	Could occur once in 3-5 years.
3	Possible	Could occur once in 1-2 years.
4	Likely	Expected at least once a year.
5	Almost certain	Expected several times a year, or already occurring.

Impact scale

Rating	Band	Definition
1	Insignificant	No service disruption; negligible financial effect; no regulatory or reputational consequence; no data affected.
2	Minor	Short internal disruption; limited financial effect; handled internally; no customer data affected.
3	Moderate	Service degradation under 4 hours; moderate financial effect; customer complaints; internal information exposed.
4	Major	Payment service outage over 4 hours; significant financial effect; regulatory notification required (DORA / GDPR); customer payment or personal data exposed.
5	Severe	Prolonged outage of the payment service; severe financial effect; supervisory action by the FMA; large-scale breach of payment or personal data.

Impact dimensions considered

Operational (service availability and continuity) | Financial (direct loss, fines, remediation cost) | Regulatory (DORA, GDPR, PSD2/ZaDiG 2018 obligations and FMA supervision) | Reputational (merchants, partners, public) | Information security (confidentiality, integrity and availability of payment and personal data). The impact rating is the highest single dimension reached, not an average.

Risk acceptance criteria (applied to the residual level)

Residual level	Decision rule
Low (1-4)	May be retained by the relevant risk owner, with periodic review.
Medium (5-9)	May be retained with a documented rationale, a named approver and a review date.
High (10-15)	Requires treatment; retention only as a formally approved management exception.
Critical (16-25)	Requires treatment; retention not permitted.

Retention of a residual risk requires a documented rationale, a named approver and a review date. Risk acceptance is a management decision taken by the risk owner, not by the analyst preparing the assessment.

All bands, thresholds and criteria are illustrative assumptions defined for this fictional case study. In a real ISMS they would be set and approved by management.

Risk Matrix — 5x5 heat maps

Likelihood (rows, 1-5) x Impact (columns, 1-5). Cells show Risk IDs. Generated from the Risk Register sheet.

Inherent risk (before existing controls)

	Impact 1	Impact 2	Impact 3	Impact 4	Impact 5
Likelihood 5				R-03	
Likelihood 4			R-09	R-01, R-05, R-10, R-11	R-02, R-04
Likelihood 3			R-13	R-06, R-07, R-12, R-14	R-08
Likelihood 2			R-15	R-16	
Likelihood 1					

Residual risk (considering existing controls)

	Impact 1	Impact 2	Impact 3	Impact 4	Impact 5
Likelihood 5					
Likelihood 4					
Likelihood 3		R-13	R-03, R-06, R-10, R-11	R-05	
Likelihood 2		R-09	R-07, R-14, R-16	R-01, R-04, R-08, R-12	R-02
Likelihood 1			R-15		

Risk Summary — VindobonaPay GmbH

Version 1.1 — all values calculated automatically (COUNTIF) from the Risk Register sheet.

Total risks	16
-------------	----

BY INHERENT LEVEL	
Critical (16-25)	7
High (10-15)	6
Medium (5-9)	3
Low (1-4)	0

BY RESIDUAL LEVEL	
Critical (16-25)	0
High (10-15)	2
Medium (5-9)	12
Low (1-4)	2

BY TREATMENT DECISION	
Modify/Mitigate	12
Retain/Accept	3
Share/Transfer	1
Avoid	0

Note: no risk remains at Critical residual level. Two risks remain High and are treated, not retained, in line with the acceptance criteria. Retained risks include rationale, approver and review date in the register.